



Relatorio Comparativo OWASP ZAP - Oficina FIAP API

Comparativo entre a varredura autenticada anterior e a nova varredura apos os fixes de seguranca aplicados no commit [22132e6](#).



Escopo e Fontes

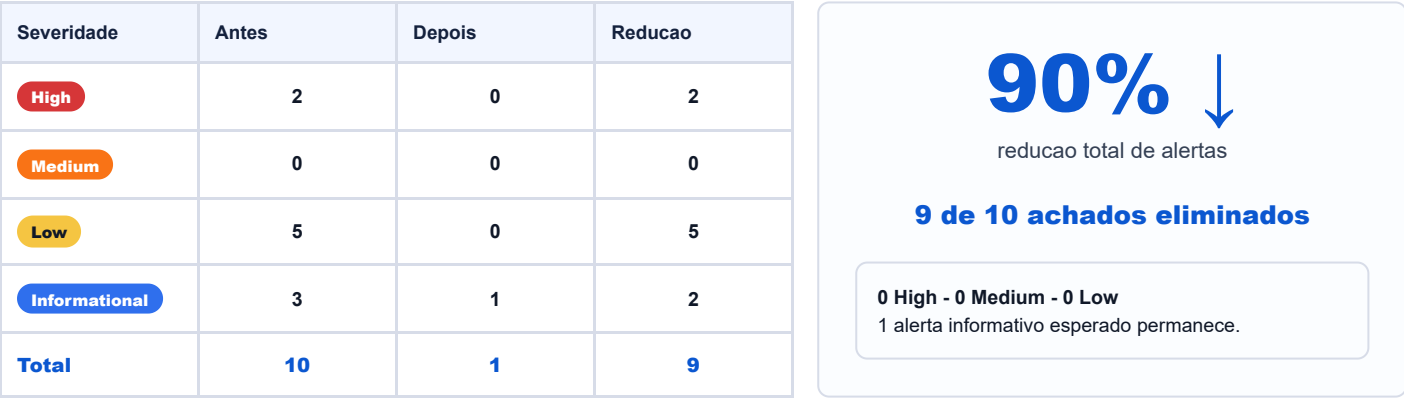
Aplicacao: NestJS API em `http://localhost:8090/api/v1`.

Scan anterior: 2 High, 0 Medium, 5 Low, 3 Informational.

Novo scan: 2026-08-27T23:05:25.777705100Z - `.zap-output/zap-authenticated-report.json`.

Executado em ambiente Docker de scan com volume limpo; o arquivo temporario contendo token de autenticacao do ZAP foi removido apos a execucao.

Resumo Executivo



Vulnerabilidades, Risco, Correcao e Evidencia

1	SQL Injection High Antes 1 / Depois 0 Endpoint/evidencia anterior: POST /api/v1/stock - Payload observado pelo scanner no campo code, ex.: OIL-FILTER-123 AND 1=1 --	IMPACTO OU RISCO Entrada fora do dominio poderia contaminar dados de estoque, aumentar a superficie de ataque e gerar suspeita de injecao em scanners de seguranca.	ACAO REALIZADA O value object PartCode passou a aceitar apenas letras, numeros, ponto, hifen e sublinhado. Foram adicionados testes unitarios e e2e para rejeicao com HTTP 400.	EVIDENCIA DO NOVO SCAN Novo scan: 0 alertas High e nenhum alerta de SQL Injection.
2	Path Traversal High Antes 1 / Depois 0 Endpoint/evidencia anterior: POST /api/v1/stock - Payload observado pelo scanner no campo code, ex.: ../etc/passwd e valores com barra.	IMPACTO OU RISCO Caracteres de caminho em codigo de peca nao fazem parte do dominio e podem sugerir tentativa de acesso indevido a arquivos ou rotas internas.	ACAO REALIZADA A mesma validacao do PartCode bloqueia barras e sequencias de caminho antes da persistencia.	EVIDENCIA DO NOVO SCAN Novo scan: 0 alertas High e nenhum alerta de Path Traversal.

3	Application Error Disclosure LowAntes 1 / Depois 0 Endpoint/evidencia anterior: POST /api/v1/purchase-orders - HTTP/1.1 500 Internal Server Error	IMPACTO OU RISCO Erro 500 em entrada manipulada indica execucao nao tratada e pode expor comportamento interno da API.	ACAO REALIZADA Violacao unica do Prisma (P2002) no numero do pedido agora e traduzida para 409 Conflict.	EVIDENCIA DO NOVO SCAN Novo scan: alerta ausente.
4	Information Disclosure - Debug Error Messages LowAntes 1 / Depois 0 Endpoint/evidencia anterior: POST /api/v1/purchase-orders - Internal server error	IMPACTO OU RISCO Mensagens de erro interno ajudam a localizar pontos sem tratamento e aumentam ruido operacional.	ACAO REALIZADA A traducao de P2002 para 409 Conflict removeu o erro interno observado no POST de purchase orders.	EVIDENCIA DO NOVO SCAN Novo scan: alerta ausente.
5	Timestamp Disclosure - Unix LowAntes 1 / Depois 0 Endpoint/evidencia anterior: GET /api/v1/client - 1786676125, interpretado pelo ZAP como 2026-08-13 23:55:25	IMPACTO OU RISCO Pode indicar exposicao de dados temporais agregaveis. Neste caso, a evidencia nao apareceu em base limpa e era compativel com dado criado pelo active scan anterior.	ACAO REALIZADA Nova varredura foi executada em ambiente Docker com volume limpo e a resposta fresca de /client foi conferida antes do scan.	EVIDENCIA DO NOVO SCAN Novo scan: alerta ausente.
6	Missing Anti-MIME-Sniffing Header LowAntes 1 / Depois 0 Endpoint/evidencia anterior: Todas as respostas HTTP - Header X-Content-Type-Options ausente.	IMPACTO OU RISCO Sem nosniff, navegadores podem tentar interpretar conteudo com tipo incorreto.	ACAO REALIZADA A configuracao global da aplicacao passou a enviar X-Content-Type-Options: nosniff.	EVIDENCIA DO NOVO SCAN Novo scan: alerta ausente.
7	Technology Disclosure por Header LowAntes 1 / Depois 0 Endpoint/evidencia anterior: Todas as respostas HTTP - Header X-Powered-By expunha detalhe da stack.	IMPACTO OU RISCO Divulgar tecnologia reduz o esforco de enumeracao para um atacante.	ACAO REALIZADA A configuracao global remove o header X-Powered-By do Express.	EVIDENCIA DO NOVO SCAN Novo scan: alerta ausente.
8	Authentication Request Identified InformationalAntes 1 / Depois 1 Endpoint/evidencia anterior: POST /api/v1/auth/login - Endpoint de login identificado pelo scanner.	IMPACTO OU RISCO Achado informativo. O endpoint existe para receber credenciais e emitir tokens.	ACAO REALIZADA Sem correcao necessaria. O endpoint permanece documentado e protegido pelo fluxo normal de autenticacao.	EVIDENCIA DO NOVO SCAN Novo scan: permanece 1 alerta informativo esperado em /api/v1/auth/login.
9	User Agent Fuzzer InformationalAntes 1 / Depois 0 Endpoint/evidencia anterior: GET /api/v1/billings - Variacoes de User-Agent testadas pelo ZAP.	IMPACTO OU RISCO Achado informativo usado para registrar comportamento durante fuzzing de headers.	ACAO REALIZADA Sem mudanca funcional necessaria; os fixes de hardening e validacao foram mantidos no escopo da API.	EVIDENCIA DO NOVO SCAN Novo scan: alerta ausente.
10	Informational Scanner Finding InformationalAntes 1 / Depois 0 Endpoint/evidencia anterior: Fluxo autenticado da API - Achado informativo adicional contabilizado no relatorio anterior.	IMPACTO OU RISCO Nao indicava explorabilidade direta, mas entrava na contagem de acompanhamento do scan.	ACAO REALIZADA Nova execucao autenticada apos os fixes consolidou os achados informativos restantes.	EVIDENCIA DO NOVO SCAN Novo scan: apenas Authentication Request Identified permanece.

Evidencia do Novo Scan

Alerta atual	Severidade	Ocorrencias	Instancia/evidencia
Solicitação de autenticação identificada	Informativo (Alto)	1	POST http://localhost:8090/api/v1/auth/login - evidencia: password